

Case Study

Northfield Health System — Clinical Documentation & Prior Authorization AI Assistant

Confidential Internal Engagement Documentation

Engagement Period: April 2025 – March 2026

- [1. Executive Summary](#)
- [2. Client Background](#)
- [3. Business Problem](#)
- [4. Constraints](#)
- [5. Discovery Transcript](#)
 - [5.1 Kickoff — Week 1](#)
 - [5.2 Clinician Shadowing — Week 2](#)
 - [5.3 Utilization Management Shadowing — Week 3](#)
 - [5.4 Capability Mapping and ROI — Week 4](#)
- [6. Architecture Workshops](#)
 - [6.1 Data & Information Architecture](#)
 - [6.2 AI/Platform Architecture — Whiteboard Session, Week 9](#)
 - [6.3 Security & Identity Architecture](#)
 - [6.4 Integration & API Strategy](#)
- [7. Technical Debates](#)
 - [7.1 Real-Time Transcription Architecture — Streaming vs. Batch](#)
 - [7.2 Should the Payer-Policy-Monitoring Agent Auto-Update the Knowledge Graph?](#)
 - [7.3 Evaluation Strategy Debate](#)
- [8. Executive Reviews](#)
 - [8.1 Clinical Governance Committee Review — Week 18](#)
 - [8.2 Revenue Cycle Executive Review — Week 24](#)
 - [8.3 Post-Incident Security Review — Week 40 \(see Section 14\)](#)
- [9. Final Architecture](#)
- [10. Delivery Roadmap](#)
- [11. Risks](#)
- [12. Governance Model](#)
- [13. Production Rollout](#)
- [14. Production Incident — Month 5](#)
 - [14.1 Incident Summary](#)
 - [14.2 Incident Response Transcript](#)
 - [14.3 Remediation](#)
- [15. Lessons Learned](#)
- [16. Enterprise Architecture Artifacts](#)
- [17. Architecture Decision Records \(ADRs\)](#)
- [18. AI Evaluation Strategy](#)
- [19. Operational Runbook](#)
- [20. Future Roadmap](#)

1. Executive Summary

Northfield Health System, a nine-hospital regional network with 140 affiliated outpatient clinics, engaged an Enterprise AI Architecture team to address two connected sources of clinician burnout and revenue leakage: excessive time spent on clinical documentation, and a prior-authorization process that was delaying care and burying utilization-management staff in paperwork.

The twelve-month engagement delivered an ambient clinical documentation assistant integrated with Epic, a prior-authorization drafting and evidence-retrieval agent grounded in a clinical-guidelines knowledge graph, and a hybrid-search retrieval layer spanning structured EHR data and unstructured clinical notes — all built under the constraints of HIPAA, a multi-state data residency posture following a recent merger, and a clinical-governance model requiring physician sign-off on any workflow touching a treatment-relevant recommendation.

Five months into production, a serious incident occurred: a prompt-injection vulnerability in the referral-fax-to-text ingestion pipeline (a legacy interoperability gap common across U.S. healthcare) allowed adversarial text embedded in a scanned referral document to manipulate a downstream summarization agent, resulting in a near-miss exposure of PHI across a patient-matching boundary. No patient harm occurred and no external breach was confirmed, but the incident triggered a full security architecture redesign of the ingestion layer and a mandatory HIPAA breach-risk assessment.

Key outcomes: - Physician documentation time reduced by an average of 87 minutes per clinical day across pilot service lines - Prior-authorization turnaround time reduced from an average of 6.2 days to 2.1 days for in-scope specialty referrals - One Class 1 security incident (near-miss, no confirmed external exposure) triggering ingestion-layer redesign and expanded breach-risk governance - Zero instances of the ambient documentation assistant's output being used as the sole basis for a treatment decision — physician attestation required on every note

2. Client Background

Northfield Health System was formed via a merger eighteen months prior to engagement start, combining two previously independent regional systems — one operating primarily in a state with stringent supplemental health-data privacy law beyond HIPAA baseline, the other in a more permissive regulatory environment. The merger left Northfield with two Epic instances mid-consolidation, a fragmented identity system, and clinical staff across the combined system reporting significant EHR-driven burnout, a top-three retention risk per Northfield's own workforce survey.

Northfield's Chief Medical Information Officer, Dr. Renata Ibhawoh, sponsored the engagement alongside the VP of Revenue Cycle, Tom Alcaraz, whose department was absorbing the operational pain of prior-authorization delays — Northfield's payer mix included several plans with notoriously slow and document-heavy prior-auth requirements for specialty imaging and infusion therapies.

3. Business Problem

Discovery identified two interlocking problems that Northfield's leadership had previously treated as separate initiatives:

Documentation burden. Physicians were spending, by their own time-tracking estimates, nearly two hours per clinical day on documentation — much of it after hours (“pajama time”), a well-documented driver of burnout across the industry. Existing EHR-embedded dictation tools were unpopular; clinicians described them as producing notes that required more editing than writing from scratch would have taken.

Prior authorization delays. Northfield's utilization-management staff manually assembled clinical evidence packages to justify prior-authorization requests, cross-referencing payer-specific medical necessity criteria (which varied by payer and changed frequently) against the patient's clinical history scattered across notes, labs, and imaging reports. A specialty infusion referral could take over a week to authorize, during which patients sometimes discontinued care-seeking altogether — a genuine clinical-quality concern, not just an administrative one.

4. Constraints

1. **HIPAA and supplemental state privacy law.** The post-merger entity had to satisfy the more stringent of its two states' requirements system-wide rather than maintaining two different privacy postures, per Legal's determination — a decision that materially shaped the data architecture (Section 6.1).
 2. **Clinical governance.** Northfield's Chief Medical Officer required that no AI output be treated as, or capable of being mistaken for, a physician's clinical judgment. Every ambient-documentation-generated note required explicit physician attestation before becoming part of the legal medical record.
 3. **Epic integration constraints.** Northfield ran two Epic instances (pending consolidation, not complete during the engagement), each with slightly different configuration, module licensing, and custom fields — the architecture had to function against both without assuming consolidation would complete on the original schedule (it did not; see Section 15).
 4. **Payer-specific medical necessity criteria** changed on each payer's own schedule, often without advance notice, and were not available via any standardized machine-readable API — most were published as PDF policy documents.
 5. **Legacy interoperability gaps.** A meaningful share of specialist referrals arrived via fax (still common in U.S. healthcare) or as scanned PDFs from non-Epic-integrated community physician offices, requiring OCR and document-understanding pipelines rather than clean structured data.
 6. **No PHI to external, non-BAA-covered services.** Any AI vendor or model provider required a signed Business Associate Agreement (BAA) under HIPAA before any PHI could flow to it, ruling out several otherwise-attractive tools during procurement.
-

5. Discovery Transcript

5.1 Kickoff — Week 1

Present: Dr. Renata Ibhawoh (CMIO), Tom Alcaraz (VP Revenue Cycle), Chief Compliance Officer (Denise Okafor), the Enterprise AI Architect (EAA).

Ibhawoh: I need to say something that might sound obvious but gets lost in vendor pitches constantly: my physicians do not want an AI that tells them what to do clinically. They want an AI that gets the busywork off their plate. If this system ever reads like it's making a clinical suggestion rather than transcribing and organizing what the physician already said and did, it will fail on trust alone, before we even get to the compliance conversation.

EAA: That's a critical distinction and I want to build it into the architecture explicitly rather than as a policy statement layered on top. Ambient documentation should be a faithful, well-organized record of the encounter as it happened — not a generator of clinical content the physician didn't originate. Where I'd push a little further: even summarization introduces judgment calls about what to include or emphasize. I want your clinical informatics team directly involved in reviewing note templates and summarization behavior, not just IT and vendor engineering, precisely because those judgment calls have clinical weight even when the system isn't "deciding" anything.

Okafor (Compliance): On the prior-auth side, my concern is different — it's about accuracy of clinical evidence citation. If we're assembling an evidence package to justify medical necessity to a payer, and the AI misrepresents or overstates what's in the chart, that's not just an administrative problem, it edges toward something that could look like fraudulent claims support if we're not careful.

EAA: That's a sharp and important framing, and it should set the evidentiary bar for that part of the system: every clinical claim in a prior-auth package needs to be directly traceable to a specific note, lab result, or imaging report — no synthesis or interpretation beyond what's explicitly documented. That's a similar grounding discipline to what I've seen matter in other regulated-numeric-claims contexts, applied here to clinical evidence citation instead of financial figures.

Alcaraz: And I need this to actually move the turnaround-time needle, or Revenue Cycle leadership isn't going to keep funding it past a pilot.

5.2 Clinician Shadowing — Week 2

Physician (Dr. Marcus Webb, internal medicine, no relation to prior engagement's CFO): Watch what happens after this patient leaves. [opens EHR] I've got fifteen more minutes of documentation for a twenty-minute visit. And half of what I'm typing is stuff I already said out loud during the visit — the review of systems, the assessment, the plan. If something could just listen and structure that, I'd get my evenings back.

EAA: What happens today when you use the existing dictation tool?

Webb: It transcribes what I say, but it doesn't understand clinical structure — I get a wall of text I then have to reorganize into SOAP format myself, which sometimes takes almost as long as just typing would have.

This shadowing session shaped the decision to prioritize **structured, template-aware ambient documentation** — not just transcription, but real-time organization into the clinical note structures physicians already used — over a generic dictation-to-text tool, differentiating the solution from Northfield's prior unsuccessful tooling.

5.3 Utilization Management Shadowing — Week 3

UM Nurse (Patricia Nguyen): For this infusion referral, I need to prove medical necessity against [Payer X]'s criteria — which, by the way, changed two months ago and nobody told us until three of our requests got denied. I have to manually find the relevant lab values, prior treatment failures, and diagnosis codes across probably six different chart sections, then write a justification letter citing all of it.

EAA: How do you currently track when a payer's criteria change?

Nguyen: Badly. Usually we find out when we get denied and have to appeal.

This directly shaped the decision to build a **payer policy monitoring capability** — not originally scoped in the RFP — that would track known payer medical-necessity policy documents for changes and flag affected in-flight

authorizations, described further in Section 6.1.

5.4 Capability Mapping and ROI — Week 4

Capability	Current State	AI Opportunity	Impact	Feasibility
Clinical documentation	Manual typing / unstructured dictation	Ambient, template-aware documentation assistant	Very High	Medium
Prior-auth evidence assembly	Manual chart review	Grounded evidence-retrieval and drafting agent	High	Medium
Payer policy monitoring	Reactive (denial-triggered)	Automated policy-change monitoring agent	Medium-High	Medium
Coding assistance	Partially automated (existing tool)	Out of scope — existing tool adequate	Low	N/A
Patient-facing chat/triage	None	Explicitly deferred — clinical risk too high for phase 1	High (if done well)	Low

EAA: I want to flag the patient-facing triage idea, which came up in the RFP, as something I’d recommend against for this phase, not just deprioritize quietly. A patient-facing conversational AI making or implying clinical triage judgments is a materially different risk category than clinician-facing documentation support, and I don’t think this engagement’s timeline or governance maturity supports doing it responsibly yet.

Ibhawoh: Agreed, and frankly relieved to hear you say that rather than sell it to us.

6. Architecture Workshops

6.1 Data & Information Architecture

Enterprise Data Architect (Grace Lin, engaged across two of this consultancy's healthcare accounts):

Lin: Given the merger, how do we handle the fact that we effectively have two Epic instances with different patient identifiers for what might be the same patient in edge cases?

EAA: This is a real and somewhat underappreciated risk — patient-matching errors in a system feeding an AI summarization or evidence-retrieval pipeline aren't just a data-quality nuisance, they're a PHI cross-contamination risk if a summarization agent pulls context from the wrong patient's record due to an identity-matching failure. I'd recommend the retrieval layer never resolve patient identity fuzzily — any patient-matching ambiguity should hard-fail into a manual-review queue rather than the system guessing and proceeding. That's a conservative design choice that costs some automation coverage but is the right tradeoff given what's at stake.

Compliance Officer Okafor: That's exactly the posture I need documented for our merger-related privacy risk assessment.

The knowledge architecture combined: - A **Clinical Guidelines & Payer Policy Knowledge Graph**, encoding both established clinical guidelines (for documentation-quality checks) and payer-specific medical necessity criteria (for prior-auth evidence assembly), with the payer-policy portion actively monitored for changes per the Week 3 finding - **Hybrid search** over structured EHR data (labs, medications, diagnoses — queried directly, not via LLM interpretation) and unstructured clinical notes (vector-indexed for semantic retrieval), with the retrieval layer enforcing strict patient-identity scoping as described above

6.2 AI/Platform Architecture — Whiteboard Session, Week 9

EAA: [at whiteboard] Ambient documentation flow: audio captured during the encounter (with patient consent per Northfield's existing consent workflow, unchanged by this project) is processed by a real-time transcription and structuring pipeline, organizing content into the physician's preferred note template as it's spoken. Nothing is written to the legal medical record until the physician reviews and explicitly attests to the note — that attestation step is a hard gate in the EHR write-back integration, not a UI suggestion that could be skipped.

Platform Architect (Sam Ito, also engaged across accounts): What's the model doing exactly — is it generating clinical content, or organizing what was said?

EAA: This is the line Dr. Ibhawoh drew in Week 1, and I want to be precise about it because it's easy to blur in practice. The model's job is structuring and lightly synthesizing *what was said and observed during the encounter* — not generating new clinical content, differential diagnoses, or recommendations the physician didn't originate. Where this gets genuinely hard: a physician might say something informally ("her breathing sounds a little rough, probably nothing but let's keep an eye on it") that needs to become a properly structured clinical observation. That's synthesis, and it's exactly the kind of judgment call I flagged in discovery that needs clinical informatics review, not just engineering judgment, built into the template design and ongoing QA process.

Ito: For prior-auth, walk through the evidence-grounding approach.

EAA: Same grounding discipline as the ambient documentation, applied differently: the Prior-Auth Agent retrieves candidate supporting evidence via the hybrid search layer, but every claim in the drafted justification letter must resolve to a direct citation — specific note, date, author, or specific lab result — surfaced to the UM nurse as a hyperlinked reference, not asserted as fact by the agent's own authority. The nurse reviews and can reject or edit any cited evidence before the package is submitted to the payer; the agent drafts, the nurse is accountable, mirroring the same non-decisioning principle used in the banking engagement's credit memo drafting, applied to clinical evidence instead of financial figures.

6.3 Security & Identity Architecture

- BAA in place with the LLM provider before any PHI processing; all inference within Northfield's cloud tenant boundary (Azure, consistent with existing Epic hosting relationship)
- Identity federation via Northfield's Epic-integrated SSO (SMART on FHIR-based authentication for provider-facing components), unifying access across both legacy Epic instances despite the incomplete consolidation
- Strict patient-identity-scoped retrieval (Section 6.1) enforced at the data-access layer, independently of

application-level logic

- Audit logging of every AI-assisted note's generation and every prior-auth evidence citation, retained per Northfield's existing medical-record retention policy (extended, not replaced, by this project)

6.4 Integration & API Strategy

- FHIR-based integration with both Epic instances for structured data access (labs, medications, diagnoses, encounters)
 - MCP server exposing the Clinical Guidelines & Payer Policy Knowledge Graph and the hybrid-search retrieval capability as tools consumed by both the ambient documentation and prior-auth agents — a shared tool layer chosen specifically to avoid building two separate retrieval stacks for what was fundamentally the same underlying data
 - Document-ingestion pipeline (OCR plus document-understanding) for fax and scanned-PDF referrals from non-integrated community physician offices — this pipeline is the one implicated in the Month 5 incident (Section 14)
-

7. Technical Debates

7.1 Real-Time Transcription Architecture — Streaming vs. Batch

ML Engineer (Devon Park, engaged across multiple accounts): Do we process audio in real time during the encounter, or batch-process after the visit ends? Real time gives physicians a live-updating draft they can review immediately after the patient leaves; batch is architecturally simpler and cheaper.

EAA: I'd push for streaming, and the reasoning is specifically about physician workflow, not just a "better tech" preference. Dr. Webb's shadowing session showed the core pain point is *after-visit* documentation time. If the structured note is substantially ready the moment the patient walks out, that's the actual burnout-reduction win — a batch process that takes even five minutes to produce a draft reintroduces a version of the same "wait and then edit" workflow that made the existing dictation tool unpopular. The cost and complexity of streaming is worth it here because it's solving the specific problem discovery identified, not a generic nice-to-have.

Park: Streaming adds real complexity around mid-encounter context — handling interruptions, multiple speakers, partial sentences.

EAA: Agreed, and I don't want to understate that. We'll need diarization (distinguishing physician, patient, and any other speakers) and a tolerance for revision as the encounter continues — the structured note should be treated as a continuously-updating draft, not a series of final commits, until the physician's end-of-visit review.

7.2 Should the Payer-Policy-Monitoring Agent Auto-Update the Knowledge Graph?

Nguyen (UM team, Week 15): Once the policy-monitoring agent detects a payer criteria change, can it just update the knowledge graph automatically so evidence packages reflect the new criteria immediately?

EAA: I'd resist full automation here, and I want to explain why given it might look like an obvious efficiency win. Payer policy documents are often ambiguously worded, and misreading a criteria change could cause the system to either over-restrict (denying eligible patients evidence support they need) or under-restrict (producing evidence packages that don't actually satisfy the new criteria, causing denials). I'd propose the monitoring agent *flags* detected changes and drafts a proposed knowledge-graph update, but a human UM policy specialist reviews and approves every graph change before it goes live — similar in spirit to how the banking engagement kept the Credit Policy Knowledge Graph synchronized to a human change-control process rather than fully automating policy interpretation.

Okafor: That's the right level of caution for something feeding claims-adjacent documentation. Approved.

7.3 Evaluation Strategy Debate

EAA: For ambient documentation, I don't think a single "note quality" score is meaningful. We need at minimum: faithfulness (does the note contain only what was actually said/observed — measured via structured comparison against the encounter audio, not just physician satisfaction survey), completeness (are required note elements present for coding/billing/clinical-quality purposes), and physician edit-burden (how much post-generation editing is actually required, our real proxy for the burnout-reduction goal).

Ibhawoh: I want faithfulness measured by an independent clinical review process, not just an automated metric — automated hallucination detection in clinical text isn't mature enough for me to trust it as the sole safeguard.

EAA: Agreed, and that's consistent with how I'd want to design this regardless — an automated faithfulness screen as a fast first-pass filter, with a defined sampling rate of clinical informatics review as the actual quality bar, especially during the pilot period before we have confidence in the automated screen's own reliability.

8. Executive Reviews

8.1 Clinical Governance Committee Review — Week 18

Ibhawoh (chairing): I'm prepared to approve pilot deployment for ambient documentation in three service lines — internal medicine, cardiology, and orthopedics — conditional on the mandatory physician attestation gate being demonstrated as non-bypassable, and on clinical informatics sign-off on note templates for each service line individually, not a single generic template.

Security representative: And I want the prior-auth evidence-grounding architecture independently reviewed by Compliance before any package is submitted to a real payer, not just before general availability.

Committee: Approved with conditions as stated.

8.2 Revenue Cycle Executive Review — Week 24

Alcaraz: Pilot data on prior-auth turnaround time?

EAA: Early pilot data across two specialty lines shows turnaround dropping from an average 6.2 days to roughly 2.3 days, close to our target. The bigger surprise is upstream: UM nurses report the payer-policy-monitoring flag has already prevented at least four in-flight authorizations from being submitted against stale criteria, which would have caused automatic denials and restarted the whole cycle. That's a benefit we hadn't fully quantified in the original ROI case.

Alcaraz: Put a number on that for the board — avoided restart cycles matter more to my team than the average turnaround number, honestly.

8.3 Post-Incident Security Review — Week 40 (see Section 14)

Okafor: I need the straight assessment — did this expose us to a reportable HIPAA breach?

EAA: Based on the forensic review completed this week, our assessment is no reportable breach occurred — the manipulated summarization output was caught by the patient-identity-scoping hard-fail control described in Section 6.1 before any cross-patient PHI was actually displayed or transmitted to an unauthorized party. I want to be precise, though: that control caught this specific incident by design, but the underlying prompt-injection vulnerability in the ingestion pipeline was real and needed to be fixed regardless of whether this particular exploitation attempt succeeded in causing actual exposure.

Okafor: I'm going to want that distinction — "the vulnerability was real, the specific harm was prevented by a separate control" — documented very precisely for our breach-risk-assessment file, because it's the difference between a reportable incident and a near-miss, and I don't want any ambiguity in how we characterized it after the fact.

9. Final Architecture

- **Ambient Documentation Pipeline:** real-time streaming transcription with speaker diarization, structuring into physician-specific note templates (clinical informatics-reviewed per service line), hard-gated by mandatory physician attestation before EHR write-back
 - **Clinical Guidelines & Payer Policy Knowledge Graph:** structured, versioned representation of clinical guideline references and payer-specific medical necessity criteria, with a human-reviewed change-control process for all updates (Section 7.2)
 - **Hybrid Search Retrieval Layer:** structured FHIR-based EHR queries plus vector-indexed unstructured clinical notes, enforcing hard-fail patient-identity scoping at the data-access layer
 - **Prior-Authorization Drafting Agent:** grounded evidence retrieval and justification-letter drafting, every claim citation-linked to source documentation, UM nurse review and edit required before payer submission
 - **Payer Policy Monitoring Agent:** tracks known payer policy documents for changes, flags affected in-flight authorizations, drafts proposed knowledge-graph updates for human approval
 - **Redesigned Document Ingestion Pipeline** (post-incident, Section 14.3): hardened fax/scanned-PDF processing with adversarial input isolation
 - All LLM inference within Northfield's Azure tenant under signed BAA; no PHI to non-covered external services
-

10. Delivery Roadmap

Phase	Duration	Scope
Discovery & Clinical Governance Framework	Months 1-2	Discovery, governance committee engagement
Ambient Documentation Build & Pilot	Months 2-6	Streaming pipeline, note templates (3 service lines), attestation gate
Prior-Auth Knowledge Graph & Agent Build	Months 3-7 (overlapped)	Payer policy knowledge graph, evidence-grounded drafting agent
Combined Pilot Expansion	Months 6-9	Additional service lines, prior-auth pilot with 2 payers
Incident & Remediation	Month 5 (during pilot)	Prompt-injection near-miss, ingestion-layer redesign
Broader Rollout	Months 9-12	System-wide expansion contingent on post-incident re-validation

11. Risks

Risk	Likelihood	Impact	Mitigation	Owner
Patient-identity cross-contamination in retrieval	Low (post hard-fail design)	Very High	Hard-fail scoping at data-access layer; this control prevented the Month 5 incident from becoming a breach	Enterprise Data Architecture
Prompt injection via unstructured document ingestion	Medium (pre-remediation); Low (post)	High	Ingestion-layer redesign, input isolation (Section 14.3)	Security Architecture
Ambient documentation faithfulness drift	Low-Medium	High	Automated faithfulness screen plus sampled clinical informatics review	Clinical Informatics
Payer policy misinterpretation	Low (post human-review gate)	High	Human UM specialist approval required for all knowledge graph updates	Utilization Management
Incomplete Epic consolidation extending dual-instance complexity	Medium (realized — see Lessons Learned)	Medium	Architecture designed to function against both instances independently	Platform Architecture

12. Governance Model

- **Clinical Governance Committee** retains standing authority over any note-template or clinical-content-adjacent change, chaired by the CMIO
 - **Mandatory physician attestation:** architecturally non-bypassable gate before any AI-assisted note enters the legal medical record
 - **UM Policy Review Board:** human sign-off required for every payer-policy knowledge graph update
 - **Post-incident Security Governance addition:** mandatory adversarial-input testing for any new document-ingestion source, added to the standard change-control checklist following Section 14
-

13. Production Rollout

Pilot began in three service lines (Month 3) with heavy on-site clinical informatics support during the first six weeks — a deliberate choice given the prior unsuccessful dictation-tool rollout had suffered from inadequate clinician onboarding. The Month 5 incident occurred during this pilot window and triggered a temporary pause of the document-ingestion pipeline specifically (not the ambient documentation or core prior-auth drafting capability, which used different, unaffected ingestion paths) while remediation proceeded.

14. Production Incident — Month 5

14.1 Incident Summary

A scanned specialist referral document, faxed from a non-integrated community physician’s office and processed through the document-ingestion pipeline described in Section 6.4, contained adversarial text embedded in what appeared to be a routine clinical notes section — text apparently inserted (the forensic investigation could not conclusively determine intent versus accidental artifact from the sending office’s own systems) that was structured to resemble system instructions rather than clinical content. This text was passed into the downstream summarization agent’s context without the isolation treatment applied to structured EHR data, and the manipulated summarization briefly attempted to retrieve and include content associated with a different patient sharing a similar name — an action that was blocked by the patient-identity hard-fail scoping control (Section 6.1) before any cross-patient content was displayed to any user.

14.2 Incident Response Transcript

Security Architect (Raj Mehta, engaged across accounts): Walk me through exactly what the hard-fail control did and didn’t prevent.

EAA: It prevented the actual harm — cross-patient PHI exposure — because the retrieval layer independently validates patient identity on every data access regardless of what the LLM’s reasoning concluded it should retrieve, and that validation failed closed rather than open. What it didn’t prevent is the underlying vulnerability: unstructured, unverified free text from an external, non-integrated source reached the summarization agent’s context without the same untrusted-input isolation treatment we applied to dispatcher free-text fields in a prior aviation-sector engagement’s design pattern — a pattern that, frankly, should have been applied here from the start and wasn’t, because this ingestion pathway was treated as “just OCR output” rather than explicitly modeled as an untrusted external input surface.

Mehta: That’s a real gap. I want a full audit of every ingestion pathway in this system, not just this one, for the same class of oversight.

Okafor: And I need to understand our disclosure posture. Does this need to go to affected patients or to HHS?

EAA: That’s ultimately Compliance and Legal’s determination, not mine, but I can tell you what the forensic evidence shows: the retrieval attempt was blocked before any cross-patient content was displayed, transmitted, or persisted anywhere a human or downstream system could access it. I’d recommend treating this with the full rigor of an actual breach investigation regardless of that outcome, precisely because the vulnerability was real even though this specific attempt didn’t succeed in causing exposure.

Okafor: Agreed — we’re not going to let “it didn’t work this time” become an excuse for treating this as minor.

14.3 Remediation

The document-ingestion pipeline was redesigned to treat all content extracted from non-integrated external sources (fax, scanned PDF, any document not originating from Northfield’s own Epic instances) as untrusted input, isolated from any system-prompt-adjacent context in the same manner as the free-text dispatcher fields pattern referenced above — clearly delimited, never concatenated with elevated trust, and passed through an additional adversarial-content screening step before reaching any downstream agent. A full audit of all other ingestion pathways confirmed no other pathway had the same gap, though two were hardened proactively as a precaution.

15. Lessons Learned

1. **Every external data ingestion pathway needs to be explicitly modeled as an untrusted input surface, not implicitly assumed safe because it passes through a preprocessing step like OCR.** The team's own prior work (referenced by the EAA in the incident response) had already established the pattern for handling untrusted free text; the gap was failing to recognize that OCR-extracted document content was the same category of risk, just arriving through a different technical pathway. Future architecture reviews should explicitly enumerate every content-ingestion pathway and classify each as trusted or untrusted, rather than assuming classification is obvious from the pathway's technical mechanism.
 2. **A well-designed backstop control can prevent harm even when a vulnerability exists upstream — but the vulnerability still needs fixing.** The patient-identity hard-fail scoping control did exactly what it was designed to do. The postmortem was explicit that this should not become a reason to deprioritize the ingestion-layer fix — defense-in-depth means every layer gets fixed when found weak, not just the layer that happened to catch this particular incident.
 3. **Incomplete post-merger system consolidation (Epic instances remaining separate longer than planned) added ongoing architectural complexity the team had designed for but that increased both engineering overhead and the surface area for the kind of identity-matching edge cases implicated in this incident.** This reinforced the Week 1 architectural choice to hard-fail on ambiguous patient matching rather than probabilistically resolve it — a choice that looked conservative at the time and proved directly protective five months later.
-

16. Enterprise Architecture Artifacts

- **Capability Map:** clinical documentation and prior-authorization value chains with AI-opportunity overlay (Section 5.4)
 - **Clinical Guidelines & Payer Policy Knowledge Graph schema,** with change-control history
 - **Data Flow Diagram with Trust Boundary Annotations** (post-incident addition): every ingestion pathway explicitly labeled trusted/untrusted, maintained as a living document reviewed at each architecture change
 - **Patient-Identity Resolution Policy specification,** documenting the hard-fail-on-ambiguity design principle referenced throughout this case study
-

17. Architecture Decision Records (ADRs)

ADR-001: Ambient documentation structures and organizes only what was said/observed during the encounter; never generates new clinical content or recommendations. Status: Accepted, foundational per CMIO mandate.

ADR-002: Mandatory, architecturally non-bypassable physician attestation gate before any AI-assisted note enters the legal medical record. Status: Accepted.

ADR-003: Patient-identity resolution hard-fails to manual review on any ambiguity, rather than probabilistically resolving matches. Status: Accepted. This control prevented the Month 5 incident from becoming a confirmed breach.

ADR-004: Streaming (real-time) transcription architecture chosen over batch processing, prioritizing after-visit documentation time reduction as the primary success metric. Status: Accepted. See Section 7.1.

ADR-005: Payer policy knowledge graph updates require human UM specialist approval; monitoring agent may only flag and draft proposed changes. Status: Accepted. See Section 7.2.

ADR-006 (post-incident): All content from non-integrated external ingestion sources (fax, scanned PDF) treated as untrusted input, isolated from elevated-trust context, and passed through adversarial-content screening. Status: Accepted, emergency-scoped remediation, audited across all ingestion pathways.

18. AI Evaluation Strategy

- **Faithfulness:** automated first-pass screen comparing generated notes against encounter audio/transcript, backed by sampled clinical informatics review as the trusted quality bar (Section 7.3)
 - **Completeness:** automated check for required note elements per service-line template and coding/billing requirements
 - **Physician edit-burden:** measured as the actual proxy for the burnout-reduction goal, tracked per service line and per physician cohort (new adopters vs. experienced users) to detect adoption-curve effects separately from tool-quality effects
 - **Prior-auth evidence-grounding accuracy:** every citation independently spot-checked against source documentation on a sampling basis by UM policy specialists
 - **Post-incident adversarial ingestion testing:** mandatory for any new document-ingestion source added to the platform, modeled on the CISO-mandated suite from the aviation-sector engagement pattern referenced in Section 14.2
-

19. Operational Runbook

- **Attestation gate monitoring:** dashboard tracking any anomaly in attestation-to-write-back timing that might indicate an attempted bypass, reviewed weekly by Clinical Informatics
 - **Ingestion pathway change procedure:** mandatory trust-boundary classification and adversarial testing for any new external data source, per ADR-006
 - **Payer policy monitoring alert handling:** defined SLA for UM Policy Review Board response to flagged policy changes, given the direct link to avoided-denial-cycle value identified in Section 8.2
 - **Cross-Epic-instance consistency check:** given incomplete consolidation, a scheduled reconciliation process verifying the knowledge graph and retrieval layer behave consistently against both instances, re-run after any Epic configuration change to either instance
-

20. Future Roadmap

1. **Full rollout pending Epic consolidation completion**, now expected roughly nine months later than originally planned per the merger integration team's revised timeline — the AI platform's dual-instance-tolerant design means this delay affects operational simplicity but not functional capability, a deliberate architectural hedge that proved its value.
2. **Expansion of ambient documentation to additional service lines** beyond the original three, contingent on clinical informatics capacity to review and approve service-line-specific templates — explicitly not something to rush given the Week 1 principle that template design carries clinical weight.
3. **Patient-facing triage/chat capability**, explicitly deferred in discovery (Section 5.4), remains off the roadmap pending a separate, dedicated discovery and governance process — Ibhawoh's committee indicated this would require board-level clinical risk sign-off distinct from this engagement's governance model.
4. **Cross-payer expansion of the policy-monitoring agent** beyond the two pilot payers, prioritized by denial-volume impact per Revenue Cycle's data.
5. **Reusing the untrusted-ingestion-pathway pattern** (ADR-006) as a standing architecture-review checklist item across all of Northfield's other AI initiatives, not just this platform — a recommendation the Security Architecture team adopted organization-wide following the postmortem.